정보보안 관리지침

제정 2017. 05. 10.
개정 2019. 05. 10.
개정 2020. 09. 23.
개정 2021. 03. 10.
개정 2021. 06. 05.
개정 2023. 03. 22.

제1장 총칙

제1조(목적) 이 지침은 한국저작권보호원(이하 "보호원"이라 한다)의 정보통신망 및 정보시스템 관리·운영과 관련한 정보보안업무에 필요한 세부사항을 규정함을 목적으로 한다.

제2조(정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.

1. "정보통신망"은 유·무선을 매개로 하는 다양한 정보통신 수단에 의하여 부호·문자·음향·영상 등의 정보를 수집·가공·저장·검색·송수신하는 정보통신 체계를 말한다.
2. "정보시스템"은 서버, PC 등 단말기, 보조기억매체, 네트워크 장치, 응용프로그램 등 정보의 수집·가공·저장·검색·송수신에 필요한 하드웨어 및 소프트웨어를 말한다.
3. "정보자산"은 하드웨어, 소프트웨어, 데이터베이스, 저장매체, 네트워크 장비 등 정보의 생산·유통·이용과 관련된 자산을 말한다.
4. "전산자료"는 전산장비에 의하여 전자기적인 형태로 입력·보관 되어 있는 각종 정보 및 데이터를 말하며, 그 자료가 입력되어 있는 자기테이프, 디스크 등 보조기억매체를 포함한다.
5. "정보통신실"은 서버장비, 네트워크 장비 등이 설치되어 운용되는 장소를 말한다.
6. "정보보안" 또는 "정보보호"는 정보시스템 및 정보통신망을 통해 수집·가공·저장·검색·송수신되는 정보의 유출, 위·변조·훼손 등을 방지하기 위하여 관리적·물리

적·기술적 수단을 강구하는 일체의 행위를 말한다.

7. “정보보안측정”은 해킹, 사이버 공격, 컴퓨터바이러스 등 각종 위협 요소에 대한 보안취약성을 진단하는 제반활동을 말한다.
8. “휴대용 저장매체”는 디스켓·CD/DVD·외장형 하드디스크·USB 메모리 등 자료를 저장할 수 있는 것으로 정보시스템과 분리할 수 있는 기억장치를 말한다.
9. “시스템담당자”는 전산조직의 업무분장에 따라 담당업무와 관련된 서버장비 등을 전담하여 운영·관리하는 직원을 말한다.
10. “사용자”는 정보자산에 접근하여 이를 사용하는 자를 말하며 외주개발자, 위탁용역업체 직원 등을 포함한다.
11. “접근권한”은 정보시스템에 접속하여 정보자산을 활용할 수 있는 권한과 정보의 생성 · 변경 · 열람 · 삭제 등 이용할 수 있는 권한을 통칭하여 말한다.
12. “무선도청 탐지”란 유·무선 도청탐지장비 등을 이용하여 은닉된 도청장치 색출과 각종 도청 위해요소를 제거하는 제반활동을 말한다.
13. “통합전산실센터”라 함은 서버 · 스위치 · 라우터 등 네트워크 장치 등이 설치·운용되는 장소를 말한다.
14. “사이버공격”이라 함은 해킹, 컴퓨터바이러스, 논리폭탄, 메일폭탄, 서비스방해 등 전자적 수단에 의하여 정보통신망을 불법침입 · 교란 · 마비 · 파괴하거나 정보를 절취 · 훼손하는 공격 행위를 말한다.
15. “휴대용 저장매체 관리번호”(이하 “관리번호”라 한다)라 함은 사용 중인 휴대용 저장매체의 식별 및 관리를 용이하게 하기 위하여 부여한 번호를 말한다.
16. “정보보안 주관부서” 란 기관 정보보안업무를 총괄하며, 정보통신망을 보호하기 위한 보안대책의 수립 · 시행과 정보보안 관리실태 평가와 관련한 업무를 전담하는 부서를 말한다. <신설 2021.03.10.,2021.06.05>

제3조(적용범위) 보호원의 정보보안 업무는 이 지침에 의한 경우를 제외하고는 관계 법령 및 상위규정을 준용한다.

제2장 정보보안 기본활동

제4조(기본목표) 정보보안의 기본목표는 정보통신에 대한 보안을 강화하여 정보자원의 기밀성·무결성·가용성을 확보함으로써 정보시스템과 전산자료 등을 안전하게 관리하고 보호하는데 있다.

제5조(정보보안책임자) ① 정보보안 업무를 총괄하여 수행하기 위하여 정보보안책임자를 두며, 정보보안책임자는 정보보안 업무를 주관하는 실 또는 본부의 장으로

한다. <개정 2021.03.10., 2023. 3. 22.>
② 정보보안책임자의 임무는 다음과 같다.
1. 정보보안 정책 수립·시행
2. 정보통신망을 신·증설하는 경우 보안대책 수립
3. 정보통신실, 정보통신망 및 정보자료 등의 보안관리
4. 정보보안업무 점검 및 교육
5. 정보보안 측정
6. 사이버위협정보 수집·분석 및 보안관제
7. 정보보안 사고조사·복구 및 처리
8. 정보보안 관련 규정 제·개정
9. 정보보안 업무 지도·감독, 정보보안 감사
10. 사이버공격 초동조치 및 대응
11. '사이버보안진단의 날' 계획 수립·시행
12. 기타 정보보안과 관련된 사항

제6조(정보보안분임책임자) ① 정보보안 업무의 일부와 분야별 정보보안 업무를 수행하기 위하여 부서별로 정보보안분임책임자(이하 "분임책임자"이라 한다)를 둔다.
② 부서별 정보보안분임책임자는 각 부서의 보직자로 하며, 정보보안 주관부서 분임책임자는 정보보안 주관부서의 보직자로 한다. <전문개정 2021.03.10., 2021.06.05>
③ 분임책임자는 해당 부서의 원활한 정보보안 업무 수행을 위하여 정보보안담당자를 지정하여 운영할 수 있다.
④ 분임책임자는 제3항의 경우 또는 정보보안담당자 교체 시 정보보안책임자에게 통보하여야 한다.
⑤ 분임책임자의 임무는 다음과 같다
1. PC 및 전산자료 등에 대한 정보보안 업무 수행
2. 정보보안 측정 지원
3. 휴대용 저장매체 관련 업무

제7조(보안성 검토) ① 분임책임자는 다음 각 호의 경우 계획수립 단계부터 보안대책을 강구하고 관련 사항을 정보보안책임자와 협의하여 처리하여야 한다.
1. 정보통신망을 신·증설하거나 서버 등 정보시스템을 교체하는 경우
2. 외부기관과 연동되는 정보시스템을 신·증설할 때
3. 정보화 사업, 컨설팅 등 관련 외부 용역사업(이하 "외부 용역사업"이라 한다)을 추진할 경우

4. 정보처리·보안관제 등의 업무를 위탁하는 경우
5. 무선랜 등 무선망을 사용하여 업무를 처리하거나 원격근무 지원 등을 위한 정보시스템을 도입하는 경우
6. 기타 정보통신 운용환경 변화로 인하여 보안성 검토가 필요하다고 인정되는 경우

② 외부 용역사업 주관부서(이하 "사업주관부서"라 한다)의 장은 용역사업 계약 시 계약서에 용역사업 참여직원의 보안준수 사항과 위반 시 손해배상 책임 등을 명시하여야 한다.

③ 사업주관부서의 보직자는 별첨 1에 의한 보안요건이 구현될 수 있도록 조치하여야 한다. <개정 2021.03.10.>

④ 정보시스템 현황, 전산자료 등 용역업체에 제공이 필요한 자료는 사업주관부서에서 자료 인계인수 대장을 비치, 보안조치 후 인계인수하고 무단 복사・외부 반출을 금지한다.

⑤ 사업주관부서의 보직자는 용역사업 종료 시 외부업체의 노트북・휴대용 저장매체 등을 통해 기관 내부자료 등이 유출되는 것을 방지하기 위한 조치를 취하여야 한다. <개정 2021.03.10.>

제8조(정보보안교육) ①정보보안책임자는 자체 정보보안 교육계획을 수립하여 연 1회 이상 전 직원을 대상으로 관련 교육을 실시하여야 한다.

② 정보보안 교육의 효율성 제고를 위해 기관 실정에 맞는 정보보안 교안을 작성·활용하여야 한다.

③ 정보보안책임자는 정보보안 관련 전문기관 교육 및 기술 세미나 참석을 장려하는 등 업무 전문성을 제고하기 위하여 노력하여야 한다.

제9조(사이버보안진단의 날) ① 정보보안책임자는 매월 셋째 주 수요일을 '사이버보안진단의 날'로 지정·운영하여야 한다.

② 분임책임자는 '사이버보안진단의 날'에 소관 정보통신망 악성코드 감염여부, 정보시스템 보안 취약점 점검 등 정보보안 업무 전반에 대하여 보안진단을 실시하여야 한다.

③ 분임책임자는 제1항 및 제2항에 따른 보안진단 결과를 정보보안책임자에게 통보하여야 한다.

제3장 정보보안 관리

제10조(무선도청 탐지) ① 정보보안책임자는 도청에 따른 정보유출을 방지하기 위하여 다음 각 호의 시설 및 장소에 대한 보안대책을 강구하여야한다.

1. 기관장실·회의실 등 중요시설
2. 중요 협상·회의와 회담장소 또는 도청 의심징후가 있는 장소
3. 기타 탐지활동이 필요하다고 판단되는 시설·장소·장비

② 제1항 각 호의 시설 및 장소에 대하여 국가정보원장에게 무선도청 탐지활동을 요청할 수 있다.

제11조(불시보안점검) ① 정보보안책임자는 사용자의 보안의식 제고를 위하여 불시에 보안점검을 실시할 수 있다.

② 점검을 통해 위규사항이 적발된 자에 대해서는 주의통보 등의 조치를 할 수 있다.

제12조(정보통신실 보안관리) ① 정보보안책임자는 다음 각 호의 중요 정보 통신 시설 및 장소를 보호구역으로 설정·관리하여야 한다.

1. 통합전산실
2. 그 밖에 보안관리가 필요하다고 인정되는 정보시스템 설치 장소

②정보보안책임자는 정보통신실을 안정적으로 운용하기 위하여 보호구역으로 설정하고 다음 각 호에 해당하는 보안대책이 적절하게 시행되는지 여부를 확인하여야 한다.

1. 항시 이용하는 출입문은 한 곳으로 정하고 잠금장치
2. 방재대책, 항온·항습 설비 및 무정전 전원 장비 설치·운영
3. 통합전산실 출입통제
4. 휴대용 저장매체를 보관할 수 있는 용기 비치
5. 정전에 대비한 비상전원 공급, 시스템의 안정적 중단 등 전력관리 대책
6. 출입자 인증·식별 등을 위한 출입문 보안장치 설치 및 주야간 감시대책
7. 카메라 장착 휴대폰 등을 이용한 불법 촬영 방지 대책 등
8. 정보시스템 안전지출 및 긴급파기 계획 수립
9. 비상조명 장치 등 비상탈출 대책
10. 기타 정보통신실 보안에 필요한 사항

③ 시스템담당자 및 사용자는 정보통신실 방문 및 정보자산 반출입 시 정보보안 주관부서에 통보 및 승인 후 시행하여야 한다. <개정 2021.06.05.>

④ 시스템담당자 및 사용자의 출입은 별지 제1호 서식에 의해 기록·관리한다.

⑤ 제1항에 의해 지정된 보호구역에는 폐쇄회로TV(이하 “CCTV”라 한다)를 설치할 수 있고, CCTV의 운영 및 관리는 관계 법령 및 상위 규정을 준용한다.

제13조(정보통신시설 출입관리) ① 정보보안책임자는 외부인이 정보통신시설을 방문할 경우 반드시 신원을 확인하고 보안교육 및 보안검색 후 출입을 허용하여야 한다.
② 정보보안책임자는 불가피한 경우를 제외하고는 정보통신시설에 대한 관람 및 견학을 지양하고 외국인의 출입은 금지한다.

제14조(시스템 보안책임 범위) ① 분임책임자는 해당 소속에 필요한 정보시스템(PC·서버·네트워크장비, 정보통신기기 등을 포함한다)을 도입·사용할 경우, 사용자와 해당 시스템의 관리책임자를 지정 운용하여야 한다.
② 사용자는 개인PC등 소관 정보시스템 사용 및 본인 계정을 통한 정보통신망 접속과 관련한 보안책임을 가진다.
③ 시스템담당자는 서버·네트워크 장비 등 부서 공통으로 사용하는 정보시스템의 운용과 관련한 보안책임을 가진다.
④ 시스템담당자는 해당 부서의 정보시스템 변경 즉시 정보보안책임자에게 통보하여야한다.
⑤ 정보보안책임자는 제1항부터 제4항까지에 명시된 정보시스템 운용과 관련한 보안취약점을 발견하거나 보안대책 강구가 필요하다고 판단할 경우, 사용자 및 시스템담당자에게 시정을 요구할 수 있다.

제15조(정보시스템 보안관리) ① 시스템담당자는 각종 정보시스템이 비인가자에게 불필요한 서비스를 허용하지 않도록 하여야 한다.
② 시스템담당자는 비인가자의 정보시스템 침입 사실을 인지한 경우에 시스템 보호를 위한 초동조치를 취하고, 지체 없이 정보보안책임자에게 보고하여야 한다.
③ 시스템담당자는 정보시스템에 대한 원격 접속을 허용하지 않아야 한다. 다만, 원격 접속이 부득이한 경우, 정보보안책임자의 승인을 받아야 하며 그 내역을 별지 제2호 서식에 의해 기록·관리하여야 한다.
④ 정보보안책임자는 보안이 취약한 무선통신망의 설치 또는 증설을 최소한으로 제한하여 운영하여야 한다.

제16조(사용자계정 관리) ① 시스템담당자는 정보시스템 불법접속에 대비하여 사용자계정(ID)에 대하여 다음 각 호의 사항을 반영하여 관리하여야 한다.
1. 사용자별 또는 그룹별 접근권한 부여
2. 외부 사용자에 대한 계정 부여는 원칙적으로 불허하되 부득이한 경우, 각 보직자의 승인을 받아 허용 <개정 2021.03.10.>

3. 비밀번호가 없는 사용자계정 사용 금지
4. 비밀번호 5회 이상 실패 시 1분 이상 접속제한

② 시스템담당자는 퇴직 또는 보직변경 등으로 사용하지 않는 사용자계정이 발생할 경우 이를 신속히 삭제하여야 한다.

제17조(비밀번호 관리) 비밀번호는 다음 각 호 사항을 반영하여 영문 대소문자, 숫자, 특수문자를 포함하여 9자리 이상으로 정하고, 분기에 1회 이상 주기적으로 변경해 사용하여야 한다.

1. 사용자계정(ID)을 포함한 비밀번호 설정 금지
2. 개인 신상 및 부서명칭 등과 관계가 없는 비밀번호 설정
3. 동일단어 또는 숫자를 반복하여 사용 금지
4. 이미 사용된 비밀번호는 재사용 금지
5. 동일 비밀번호를 여러 사람이 공유하여 사용 금지
6. 일반 사전에 등록된 단어의 사용금지
7. 응용 프로그램 등을 이용한 자동 비밀번호 입력기능 사용금지

제18조(정보통신망 현황·자료 관리) 정보보안책임자는 다음 각 호의 자료를 대외비로 분류하여 적절하게 관리하여야 한다.

1. 정보시스템 운용현황
2. 정보통신망 세부 구성현황(IP 세부 할당현황을 포함한다)
3. 정보보안시스템 운용현황
4. 보안취약성 분석·평가 결과물
5. 기타 보호할 필요가 있는 정보통신망 관련 자료

제19조(전자우편 등의 보안관리) ① 사용자는 상용 전자우편을 이용하여 업무자료를 송 · 수신 할 수 없으며 기관 전자우편으로 송 · 수신한 업무자료는 활용 후 메일함에서 즉시 삭제하여야 한다.

② 사용자는 출처가 불분명하거나 의심되는 제목의 전자우편은 열람하지 않고 악성메일로 의심되는 전자우편은 즉시 정보보안책임자에게 신고하여야 한다.

③ 정보보안책임자는 웜 · 바이러스 등 악성코드로부터 사용자PC등 전자우편 시스템 일체를 보호하기 위하여 백신, 바이러스 월, 해킹메일 차단시스템을 구축하는 등 보안대책을 강구하여야 한다.

④ 사용자는 메일에 포함된 첨부파일이 자동 실행되지 않도록 설정하고 첨부파일 다운로드 시 반드시 최신 백신으로 악성코드 은닉여부를 검사하여야 한다.

⑤ 정보보안책임자는 발신지 IP주소와 국가명이 표시되고, 해킹 메일 원본을 전송

하여 신고할 수 있는 기능을 갖춘 웹메일시스템을 구축하여야 한다. 다만, 웹메일 시스템을 직접 구축 · 운영하지 않은 경우에는 그러하지 아니하다.
⑥ 정보보안책임자는 보안상의 문제점을 발생시키거나 업무에 심각한 지장을 가져올 수 있다고 판단되거나 상용 전자우편을 서비스하는 인터넷 사이트는 접속을 제한할 수 있다.
⑦ 사용자는 전자우편을 사용하는 PC에 대하여 제30조(PC 등 단말기 보안관리)에 명시된 보안조치 사항을 따른다.

제20조(공개서버 관리) ① 정보보안책임자는 웹서버 등의 공개서버 운영 시 침입차단·탐지시스템을 설치하여야 한다.
② 시스템담당자는 서버에 접근할 수 있는 사용자계정을 제한하여야 하며 불필요한 계정은 삭제하여야 한다.
③ 홈페이지 게재내용은 해당 보직자의 보안성 검토를 거쳐 비밀내용 등 비공개 자료가 포함되지 않도록 하여야 한다. <개정 2021.03.10.>
④ 공개서버는 업무서비스를 제외한 모든 서비스 및 시험·개발도구 등으로 사용하지 않도록 제한하여야 한다.

제21조(정보보호시스템 도입) 정보통신망 및 정보시스템을 보호하기 위하여 상용 정보보호시스템 또는 정보보호 기능이 탑재된 정보시스템을 도입하고자 하는 경우 국가정보원 보안적합성 검증필 제품을 우선적으로 검토하여야 한다.

제22조(원격근무 보안관리) ① 정보보안책임자는 원격근무 시행 시 원격접속 보안 프로그램으로 내부 정보시스템에 접근할 수 있도록 지원하여야 한다.
② 정보보안책임자는 정보보안측정을 이행하는 경우 원격근무자에 대한 보안점검을 실시하여 정보보안관리지침의 이행 여부를 확인할 수 있다.
③ 정보보안책임자는 원격근무 허용 범위를 제한하여 운영하여야 하며, 대외비 이상의 비밀자료를 취급하는 업무는 원격근무 대상에서 제외하여야 한다.
④ 원격근무자는 다음 각 호의 사항이 있을 때에는 지체 없이 정보보안책임자에게 보고하여야 한다.

1. 원격근무지원시스템 접속용 사용자(Client) 프로그램이 설치된 PC 또는 노트북을 분실하는 경우
2. 원격근무지원시스템 접속용 인증서를 분실하는 경우
3. 원격근무지원시스템 사용자계정 및 비밀번호가 외부에 노출되는 경우 등

⑤ 시스템담당자는 원격근무자의 신상이 변동되거나 퇴직하는 경우 사용자 계정을 즉시 삭제하여야 한다.

⑥ 정보보안책임자는 원격근무자를 대상으로 연 1회 이상의 보안교육을 실시하여야 한다.

제23조(정보보안 측정) ① 정보보안책임자는 정보통신시스템에 대한 각종 위협으로부터 보안상 취약성을 진단하기 위하여 정보보안 측정을 실시하여야 한다.
② 정보보안 측정은 다음 각 호의 경우에 실시하여야 한다.
1. 정보통신 보안사고가 발생하여 정보통신망의 취약성 진단이 요구되는 경우
2. 정보시스템에 대한 보안성 검토와 보안시스템 설치, 보안대책 등에 대해 상급기관에서 확인이 요구되는 경우
3. 정보통신망에 관한 취약성 점검 또는 종합 진단이 필요하다고 판단되는 경우

제24조(정보보안 사고 처리) ① 정보보안책임자는 정보보안 사고가 발생한 때에는 즉시 피해를 최소화하도록 조치를 취하고 다음 각 호의 사항을 원장에게 즉시 보고하여야 한다.
1. 일시 및 장비
2. 사고원인, 피해현황 등 개요
3. 사고자 및 관계자의 인적사항
4. 조치내용 등
② 정보보안책임자는 보안사항 위반자에 대하여 별첨 2의 보안위규 처리 기준에 따라 조치 할 수 있다.

제25조(정보시스템 반출입) ① 정보시스템을 폐기·양도·교체·반납하거나 외부수리 등을 위해 외부로 반출할 경우 사전에 정보보안책임자의 승인을 받아야 하며, 그 현황을 별지 제3호 서식에 의해 기록하여야 한다.
② 분임책임자는 저장매체의 고장수리·저장자료 복구 등을 외부에 의뢰할 경우 저장매체에 저장된 자료의 유출 방지를 위해 수리 또는 복구업체에 대하여 보안서약서 등 필요한 조치를 하여야 한다.

제26조(저장자료 삭제확인) ① 정보보안책임자 또는 분임책임자는 정보시스템 또는 저장매체(하드디스크 · 반도체 기반 저장장치(SSD) 등)를 외부수리 · 교체 · 반납 · 양여 · 폐기 · 불용 처리하고자 할 경우 정보시스템 및 저장매체에 저장된 자료가 외부에 유출되지 않도록 자료 삭제 등 보안조치를 실시하여야 한다.
② 정보시스템에 저장된 자료의 삭제를 외부업체에 의뢰할 때에는 정보보안책임자 또는 분임책임자가 입회하여 삭제 절차·방법 준수여부 등을 확인 감독하여야 한다.

③ 정보보안책임자는 정보시스템을 불용처리할 경우 해당 시스템의 사용기관·부서·사용자 등을 인식할 수 있는 표시를 모두 제거하여야 한다.

제27조(정보시스템 개발보안) ① 시스템 개발사업 담당자는 정보시스템을 자체적으로 개발하고자 하는 경우에는 다음 각 호의 사항을 고려하여 보안대책을 수립하고 정보보안책임자의 승인을 득하여야 한다.

1. 독립된 개발시설을 확보하고 비인가자의 접근 통제
2. 개발시스템과 운영시스템의 물리적 분리
3. 소스코드 관리 및 소프트웨어 보안관리
4. 소프트웨어 개발보안(시큐어코딩)

② 시스템 개발사업 담당자는 외부용역 업체와 계약하여 정보시스템을 개발하고자 하는 경우에는 다음 각 호의 사항을 고려하여 보안대책을 수립하고 정보보안책임자의 승인을 득하여야 한다.

1. 외부인력 대상 신원확인, 보안서약서 징구, 보안교육 및 점검
2. 외부인력의 보안준수 사항 확인 및 위반 시 배상책임의 계약서 명시
3. 외부인력의 정보시스템 접근권한 및 제공자료 보안대책
4. 외부인력에 의한 장비 반입·반출 및 자료 무단반출 여부 확인
5. 제1항 제1호부터 제4호까지의 사항

③ 정보보안책임자는 제1항 및 제2항과 관련하여 보안대책의 적절성을 수시로 점검하고, 정보시스템 개발을 완료한 경우에는 정보보안 요구사항을 충족하는지 검토하여야 한다.

④ 소프트웨어 개발보안에 관한 구체적인 사항은 행정안전부의 「행정기관 및 공공기관 정보시스템 구축·운영 지침」 및 「소프트웨어 개발보안 가이드」를 따른다. <개정 2021.03.10.>

제28조(영상회의시스템 보안관리) ① 정보보안책임자 또는 분임책임자는 영상회의시스템을 구축할 경우에 통신망(국가정보통신망, 전용선, 인터넷 등)에 따른 암호화 등 보안대책을 수립・시행하여야 한다.

② 기타 상세한 사항은 국가정보원의 「영상회의 관련 보안 가이드라인」을 준수하여야 한다. <개정 2021.03.10.>

제29조(스마트폰 등 모바일 행정업무 보안관리) ① 정보보안책임자 또는 분임책임자는 스마트폰 등을 활용하여 내부행정업무와 현장행정업무 및 대민서비스업무 등 모바일 업무환경을 구축할 경우 보안대책을 수립・시행하여야 한다.

② 기타 상세한 사항은 국가정보원의 「국가・공공기관의 모바일 활용업무에 대한 보

안가이드라인」을 준수하여야 한다. <개정 2021.03.10.>

제4장 휴대용 저장매체 및 PC 보안관리

제30조(PC 등 단말기 보안관리) ① 단말기 사용자는 PC · 노트북 · 스마트기기 등 단말기(이하 "PC 등"이라 한다) 사용과 관련한 일체의 보안관리 책임을 가진다.

② 사용자는 PC 등에 대한 비밀번호의 취급관리는 제17조에 따라 부여하여 관리하여야 한다.

③ 사용자는 PC 등의 보안관리를 위해 다음 각 호의 사항을 준수하여야 한다.

1. 장비(CMOS) · 사용자(로그온)별 비밀번호를 설정하고 주기적으로 변경
2. 10분 이상 작업 중단 시 비밀번호 등이 적용된 화면보호 조치
3. 백신 및 PC용 침입차단시스템 등의 운용 및 최신 보안패치 유지
4. PC 운영체제(OS) 및 응용프로그램(아래아한글, MS Office, Acrobat 등) 등의 최신 보안패치 유지
5. 업무와 무관하거나 보안에 취약한 응용프로그램 설치 및 사용금지
6. 공유폴더 사용 금지
7. IP주소 임의변경 금지
8. 컴퓨터 이름은 사용자의 성명(한글) 사용

④ 분임책임자는 PC를 교체·반납·폐기하거나 고장으로 외부에 수리를 의뢰하는 경우 하드디스크에 수록된 자료가 유출, 훼손되지 않도록 보안조치를 하여야 한다.

제31조(소프트웨어의 설치 제한) ① 소프트웨어는 업무상으로 인가된 프로그램만 사용하여야 한다.

② 정보시스템을 침해하거나 우회할 수 있는 소프트웨어를 임의로 설치하거나 시스템 운영상 설치된 프로그램을 임의로 삭제하여서는 아니 된다.

제32조(휴대용 저장매체의 관리) ① 보조기억매체는 대외비, 일반, 공인인증서용으로 구분하여 관리한다.

② 보조기억매체는 등록된 것만 사용할 수 있으며 업무목적 이외의 사적인 용도로 사용할 수 없다. 다만, 공인인증서용에 한하여 등록 후 개인소지 및 사용하도록 할 수 있다.

③ 대외비 이상의 자료는 대외비용 보조기억매체, 일반 자료는 일반용 보조기억매체를 각각 사용하며, 자료등급별로 혼용하여 사용할 수 없다.
④ 정보보안책임자는 대외비용 보조기억매체로 보안 USB를 일괄 구입하여 필요한 부서에 공급할 수 있다.
⑤ 보조기억매체는 부서 단위로 관리하는 것을 원칙으로 하며, 각 부서의 보직자가 보조기억매체 관리책임자가 된다. <개정 2021.03.10.>
⑥ 보조기억매체 관리책임자의 임무는 다음과 같다.
1. 보조기억매체의 등록·삭제·변경 및 보조기억매체 라벨 부착
2. 보조기억매체 반출입 통제
3. 별지 제4호 내지 제6호 서식의 기록·관리
4. 미등록 보조기억매체 사용 여부 관리·감독
5. 자료등급별 혼용 저장 여부 관리·감독
6. 보조기억매체의 분실·파손, 대외비 이상 자료의 유출 또는 유출 우려가 있는 경우 분임책임자 보고 및 정보보호책임자에게 통보
⑦ 정보보안 책임자는 그 소속직원이 국제회의에 참가 시 출장 전 회의 대상국에서 제공한 USB메모리 등 휴대용 저장매체를 사용하지 않도록 보안교육을 실시한다.
⑧ 정보보안 책임자는 공지·교육을 통하여 미등록 휴대용 저장매체 사용을 제한하여야 하고 이에 대해 주기적인 점검을 실시하여야 한다.
⑨ 제6항 제2호의 반출입은 업무상 목적에 한한다. 다만, 사적소지가 허용된 공인인증서용은 제외한다.
⑩ 정보보안책임자는 운용 중인 휴대용 저장매체를 안전하게 관리하기 위해 관리시스템을 구축할 수 있다. 이 경우 별지 제3호 내지 별지 제7호 서식을 갈음할 수 있다.
⑪ 각 부서의 보직자는 휴대용 저장매체의 불용처리 시 물리적 파기를 원칙으로 하고 그 사실을 관리대장에 기록하여야 한다. <개정 2021.03.10.>

제33조(휴대용 저장매체 불용처리 및 재사용) ① 휴대용 저장매체를 불용처리 시 그 사실을 관리대장에 기록하여야 한다.
② 휴대용 저장매체를 불용처리하거나 재사용하는 경우에는 별지 제7호 서식에 따라 정보보안책임자의 확인을 받아야 한다.

제34조(휴대용 저장매체의 분실, 소각 시 대처방안) ① 사용자는 휴대용 저장매체의 분실 또는 소각 등의 사유가 발생한 즉시 정보보안책임자에게 그 사실을 보고하여야 한다.

② 정보보안책임자는 일반용의 분실 또는 소각 사실을 통지받거나 인지한 경우에는 자체 조사를 실시하고 재발방지 대책을 강구하여야 한다.

제35조(휴대용 저장매체 외부수리 방안) ① 휴대용 저장매체의 고장, 자료의 훼손 또는 오인삭제, 포맷으로 자료의 복구가 필요한 경우 상용 소프트웨어를 활용하거나 민간업체에 의뢰할 수 있다.
② 제1항에 따라 민간업체에 의뢰하는 경우에는 분임정보보안책임자 입회, 보안서약서 징구 등 적절한 보안대책을 강구하여야 한다.

부 칙

이 지침은 원장의 결재를 받은 날(2017. 05. 10.)부터 시행한다.

부 칙

이 지침은 원장의 결재를 받은 날(2019. 05. 10.)부터 시행한다.

부 칙

이 지침은 원장의 승인을 받은 날(2020. 09. 23.)부터 시행한다.

부 칙

이 지침은 원장의 승인을 받은 날(2021. 03. 10.)부터 시행한다.

부 칙

이 지침은 원장의 승인을 받은 날(2021. 06. 05.)부터 시행한다.

부 칙

이 지침은 원장의 승인을 받은 날(2021. 3. 22.)부터 시행한다.

[별첨 1]

정보화사업 보안요건

□ 보안 원칙

o 심층방어(Defense In Depth) : 중요 액션에서 한번 더 인증
o 최소한의 권한(Least Privilege) : 모든 사용자에게 필요한 최소한의 권한만을 부여
o 단순화 : 불필요한 복잡한 코드는 보안상의 취약점을 야기
o 노출의 최소화 : 보안에 민감한 데이터는 일부만 노출

□ 보안 규칙

구 분	내 용	비 고
1. 파라미터	o 파라미터(POST, GET)로 넘어온 데이터의 성격을 구분 o 입력값을 필터링(숫자, 문자 구분)하여 데이터를 입력 o 출력값을 필터링(특수문자 등을 치환)하여 데이터를 출력	
2. 사용자입력	o 중요한 트랜잭션이 일어나는 프로세스에 사용자의 비밀번호를 재확인 (※ 개인정보 수정 및 비공개성 내용 등) o 사용자 입력 가능 문자들을 정의, 그 외는 필터링 o 게시판에 HTML 포맷을 사용할 수 없도록 설정 (※ HTML이 필요한 경우 해당 HTML 태그만 사용하도록)	
3. 인증	o 회원 인증과정은 서버측에서 수행 o 데이터 유효성 검증은 Server Side Script에서 구현	
4. 디렉토리 및 파일	o 관리자용 디렉토리 및 파일은 영·숫자를 조합한 이름으로 만들 것 o 관리자 페이지 접근 제한 o 파일을 다운받을 수 있는 디렉토리를 한정하고 그 외의 디렉토리에서는 파일을 다운받을 수 없도록 함 o Upload파일을 위한 디렉토리에 실행설정을 제거 o Upload 가능한 확장자 필터링 o 첨부 파일 필터링시 대소문자를 모두 검사하며, 확장자 검사는 제일 끝에 존재하는 확장자를 기준으로 점검 (※첨부 파일에 대한 검사는 반드시 Server Side Script에서 구현)	
5. 암호화	o 중요 또는 민감한 데이터는 암호화를 통해 데이터 전송 및 저장 ·주민등록번호, 패스워드 등 기타 보안이 필요한 정보	
6. 기타	o 중요 정보를 보여주는 페이지는 캐쉬를 사용하지 못하도록 설정 o 클라이언트에서 실행되는 컴포넌트에 중요 정보를 하드 코딩 금함 o 서버의 에러메시지를 사용자에게 보여주지 않도록 설정 o 개발도중에 만들어진 불필요한 파일 삭제(백업 파일 등)	

□ 보안취약점 점검 내용

점검분야	점검항목	비고
1. 접근통제 취약점	o 관리자 페이지에 특정IP만 접근 가능하도록 설정하였는가? - IIS :인터넷 서비스 관리자 → IP주소 및 도메인 이름 제한 - Apache : httpd.conf, .htaccess, htpassword 등 설정 o 관리자용 디렉토리, 파일, 계정, 패스워드 유추하기가 어려운가? o 접근제어가 필요한 모든 페이지에 통제수단(로그인 체크, 권한체크)이 구현되어 있는가? o 인증을 처리하는 페이지와 일반 페이지가 분리되어 구현되었으며 인증과정은 서버측에서 수행되는가?	
2. 부적절한 파라미터	o URL, 쿼리문자열, HTTP헤더 쿠키, HTML 폼인자, HTML hidden 필드 등 HTTP요청을 변조할 수 없으며, 이를 통해 보안 메커니즘을 우회할 가능성이 없는가? ※허용된 값만을 받아들이는 허용(Positive)방식의 인자 검증을 권고	
3. 취약 세션 관리	o 사용자의 자격 증명이 정적인 상태나 전송 중에 보호되고 있는가? ※SSL과 같은 기술을 사용하여 로그인 트랜잭션 전체 암호화를 권고 o cookie대신 보안성이 강한 Server Side Session을 사용하는가? ※ 세션방식에서 서버에서 사용자 IP정보 저장 등을 권고	
4. 악의적인 명령 실행	o 사용자 입력 가능 문자들을 정의하며, 그 문자들을 제외한 모든 문자들을 필터링하였는가? - 필터링 대상 : url파라미터, form인수값, 데이터베이스 쿼리 등 사용 입력 가능 부분 o 게시판에 HTML 포맷을 사용할 수 없도록 설정하였는가? - 필요한 경우 모든 HTML을 사용하지 못하게 설정 후 필요한 HTML Tag만 쓸 수 있도록 설정	
5. 버퍼 오버 플로우	o 서버제품군의 최신 버그 리포트의 지속적인 참고 및 패치 적용 여부	
6. 악의적 명령어 주입 공격	o 사용자 입력시 특수문자(' / ; : space -- +등)가 포함되어 있는지 검사하여 허용되지 않은 문자열이나 문자가 포함되는 경우에 에러로 처리하는가? o SQL 서버의 에러메시지를 사용자에게 보여주지 않도록 설정하였는가? o 웹 애플리케이션이 사용하는 데이터베이스 사용자의 권한을 제한하여 일반 사용자 권한으로 모든 system stored procedures에 접근할 수 없는가?	
7. 업로드 취약점	o 불필요한 첨부파일 업로드 기능이 존재하지 않는가? o Upload파일을 위한 디렉토리에 실행설정을 제거하였는가? o Upload 가능한 확장자를 필터링하는 루틴이 있는가? - 첨부 파일 필터링시 대소문자를 모두 검사하며, 확장자 검사는 제일 끝에 존재하는 확장자를 기준으로 점검 - 첨부 파일에 대한 검사는 반드시 Server Side Script에서 구현	

점검분야	점검항목	비고
8. 다운로드 취약점	o 파일을 다운받을 수 있는 디렉토리를 한정하고 그 외의 디렉토리에서는 파일을 다운받을 수 없도록 하였는가?	
9. 개발보안관리	o 사용자에게 전달된 값(Hidden form 필드, parameter)를 재사용할 수 없도록 무결성 검사를(예, 해쉬값 비교) 하는가? o 최종 통제 메커니즘은 서버에서 수행되고 있는가? o 클라이언트에서 실행되는 컴포넌트에 중요 정보를 하드 코딩하지 않는가? o 중요한 트랜잭션이 일어나는 프로세스에 사용자의 비밀번호를 재확인하며, 중요 정보를 보여주는 페이지는 캐쉬를 사용하지 못하도록 설정하였는가?	
10. 부적절한 환경설정	o 불필요한 파일이 노출되지 않았는가? - .bak, .log, .history, sample파일, 매뉴얼 파일, 기본설치파일, 임시설치파일 등 o 최소한의 사용자 계정을 사용 o 디렉토리 리스팅 금지 설정 o 심볼릭 링크, 별칭(aliases), 바로가기 설정 제거 o PUT, POST, DELETE의 제한 o 배너 정보를 숨기거나 최소화 o 에러 메시지 수정 o 관리자 페이지 접근통제 o 특정 파일의 내용 보기 방지 o 주요 파일시스템 설정 변경	

[별첨 2] <개정 2019.5.10.>

보안 위규 처리기준

구 분	위 규 사 항	처 리 기 준
심각	1. 비밀 및 대외비 급 정보 유출 및 유출시도 가. 정보시스템에 대한 구조, 데이터베이스 등의 정보 유출 나. 개인정보·신상정보 목록 유출 다. 비공개 항공사진·공간정보 등 비공개 정보 유출 2. 정보시스템에 대한 불법적 행위 가. 관련 시스템에 대한 해킹 및 해킹시도 나. 시스템 구축 결과물에 대한 외부 유출 다. 시스템 내 인위적인 악성코드 유포	○ 사업참여 제한 ○ 위규자 및 직속 감독자 교체 ○ 재발 방지를 위한 조치계획 제출 ○ 위규자 대상 특별 보안교육 실시
중대	1. 비공개 정보 관리 소홀 가. 비공개 정보를 책상 위 등에 방치 나. 비공개 정보를 휴지통·폐지함 등에 유기 또는 이면지 활용 다. 개인정보.신상정보 목록을 책상 위 등에 방치 라. 기타 비공개 정보에 대한 관리소홀 2. 사무실.보호구역 보안관리 허술 가. 통제구혁 출입문을 개방한 채 퇴근 등 나. 인가되지 않은 작업자의 내부 시스템 접근 다. 통제구역 내 장비·시설 등 무단 사진촬영 3. 전산정보 보호대책 부실 가. 업무망 인터넷망 혼용사용, USB 사용규정 위반 나. 웹하드·P2P 등 인터넷 자료공유사이트를 활용하여 용역 사업 관련 자료 수발신 다. 개발·유지보수 시 원격작업 사용 라. 저장된 비공개 정보 패스워드 미부여 마. 인터넷망 연결 PC 하드디스크에 비공개 정보를 저장 바. 외부용 PC를 업무망에 무단 연결 사용 사. 보안관련 프로그램 강제 삭제 아. 사용자 계정관리 미흡 및 오남용(시스템 불법접근 시도 등)	○ 위규자 및 직속 감독자 교체 ○ 재발 방지를 위한 조치계획 제출 ○ 위규자 대상 특별 보안교육 실시

구 분	위 규 사 항	처 리 기 준
보통	1. 기관 제공 중요정책・민감 자료 관리 소홀 가. 주요 현안・보고자료를 책상 위 등에 방치 나. 정책・현안자료를 휴지통・폐지함 등에 유기 또는 이면지 활용 2. 사무실 보안관리 부실 가. 캐비넷・서류함・책상 등을 개방한 채 퇴근 나. 출입키를 책상 위 등에 방치 3. 보호구역 출입 소홀 가. 통제・제한구역 출입문을 개방한 채 근무 나. 보호구역내 비인가자 출입허용 등 통제 불순응 4. 전산정보 보호대책 부실 가. 휴대용저장매체를 서랍・책상 위 등에 방치한 채 퇴근 나. 네이트온 등 비인가 메신저 무단 사용 다. PC를 켜 놓거나 보조기억 매체(CD, USB 등)를 꽂아 놓고 퇴근 라. 부팅・화면보호 패스워드 미부여 또는 "1111" 등 단순 숫자 부여 마. PC 비밀번호를 모니터옆 등 외부에 노출 바. 비인가 보조기억매체 무단 사용	○ 위규자 및 직속 감독자 사유서 / 경위서 징구 ○ 위규자 대상 특별 보안교육 실시
경미	1. 업무 관련서류 관리 소홀 가. 진행 중인 업무자료를 책상 등에 방치, 퇴근 나. 복사기・인쇄기 위에 서류 방치 2. 근무자 근무상태 불량 가. 각종 보안장비 운용 미숙 나. 경보・보안장치 작동 불량 3. 전산정보 보호대책 부실 가. PC내 보안성이 검증되지 않은 프로그램 사용 나. 보안관련 소프트웨어의 주기적 점검 위반	○ 위규자 서면・구두 경고 등 문책 ○ 위규자 사유서 / 경위서 징구

※ 사업자 보안위규 처리 절차

경위 확인 ▶ 보안위규 처리기준에 따라 조치 ▶ 재발방지 대책 ▶ 보안조치 이행여부 점검

[별첨 3] <신설 2019.5.10.>

정보보호시스템 유형별 도입요건

제품유형	도입요건	비고
침입차단시스템(FW) 침입방지시스템(IPS)(침입탐지 포함) 통합보안관리제품 웹 응용프로그램 침입차단제품 서버 접근통제제품 DB 접근통제제품 네트워크 접근통제제품 인터넷전화 보안제품 무선침입방지시스템 무선랜 인증제품 가상화제품 네트워크 자료유출 방지제품 디지털복합기 스마트폰 보안관리제품	CC인증	EAL 2 이상 또는 관련 PP 준수
스마트카드		EAL 4 이상
가상사설망제품 소프트웨어기반 보안USB 호스트 자료유출 방지제품	CC인증 및 검증필 암호모듈	EAL 2 이상 또는 관련 PP 준수 검증필 암호모듈 필히 적용
스팸메일차단시스템 패치관리시스템 망간자료전송제품	CC인증 또는 국가용 보안요구사항 준수 GS인증	- CC인증시 : EAL 2 이상 또는 관련 PP 준수 - GS인증시 : ISO 25023 및 국가용 보안요구사항 준수
DDoS 대응장비 안티바이러스제품 소스코드 보안약점 분석도구	CC인증 또는 국가용 보안요구사항 준수 성능평가	- CC인증시 : EAL 2 이상 또는 관련 PP 준수 - 성능평가시 : 국가용 보안요구사항 준수
행정기관용 인터넷전화	TTA verified ver.4 이상	
기타 정보보호제품	-	CC인증 및 검증필 암호모듈 탑재 권고

* 최신 도입요건은 국가정보원 홈페이지(보안적합성 검증) 참조

[별지 제1호 서식] <개정 2021.03.10.>

정보통신실 출입 관리대장						
출 입 현 황						
순번	일 시	출 입 자			사 유	담당자
		소속	성명	서명		
	~					(인)
	~					(인)
	~					(인)
	~					(인)
	~					(인)
	~					(인)
	~					(인)
	~					(인)
	~					(인)
	~					(인)
	~					(인)

확인일자 : 년 월 일

확 인 자 : 성명 : (인)

[별지 제2호 서식]

원격접속 관리대장

<관리책임자 : >

연번	장비명	사업명	접속사유	접속IP	사업주관부서	접속기간		확인
	장비IP	용역업체명		계정(ID)	담당자 (인)	시작	종료	
								(인)
					(인)			
								(인)
					(인)			
								(인)
					(인)			
								(인)
					(인)			
								(인)
					(인)			
								(인)
					(인)			
								(인)
					(인)			
								(인)
					(인)			
								(인)
					(인)			
								(인)
					(인)			
								(인)
					(인)			
								(인)
					(인)			

[별지 제3호서식]

휴대용 저장매체(전산장비 포함) 반출·입 대장

<관리책임자 : >

장비명	관리번호 (시리얼번호)	사용자	용도	출입 일시 (입·출 구분)	확인
USB	정보화-일반-01 (610-RUCW-61659)	5급 홍길○	국회 제출	2011.10.1 11:00(출)	*김유○*
CD	00-일반-03 (4589-KK-4585)	5급 유관○	법무부 회의참석	2011.10.7 09:40 (출)	*김유○*
CD	00-일반-03 (1258-JK-8935)	5급 유관○	법무부 회의참석 회수	2011.10.7 17:50(입)	*김유○*
USB	00-일반-01 (610-RUCW-61659)	5급 홍길○	국회제출 회수	2011.10.8 18:10 (입)	*김유○*
노트북PC	s111-001-113 (5004829800055)	5급 홍길○	세미나 발표	2011.12.3 13:00 (출)	*김유○*
USB	00-일반-005 (610-RUFU-61747)	5급 강감○	재택근무	2011.12.3 10:00(출)	*김유○*

[별지 제4호 서식] <개정 2021.03.10.>

휴대용 저장매체 관리대장(대외비/일반/공인인증서)

< 관리책임자 : >

연번	관리번호 (S/N)	매체형태	등록일자	취급자	불용처리일자	불용처리방법 (재사용 용도)	비고
1	00부서-일반-01 (E-D900-04-3705B)	USB	10.10.20	5급 홍길○	11.10.20	물리적 파기	고장
2	00부서-일반-02 (NP00T512787J)	외장형 HDD	10.10.25	6급 김정○	11.10.27	포맷 후 재사용 (00부서-일반-01)	
3	00부서-일반-03 (E-D900-04-3705B)	USB	10.11.1	5급 이수○	11.10.7	물리적 파기	고장
4							
5							
6							
7							
8							
9							
10							
11							
12							
13							
14							
15							

[별지 제5호 서식]

휴대용 저장매체 점검대장

< 관리리책임자 : >

점검일시	현 보유수량				이상 유무	점검관		비고 (서명)
	II급	III급	대외비	일반		성명	서명	
2011.1.3	1	1	3	15	이상무	5급 홍길○	*홍길○*	*김유○*
2011.2.1	1	1	2	16	이상무	5급 홍길○	*홍길○*	*김유○*
2011.3.1	1	1	2	16	이상무	5급 홍길○	*홍길○*	*김유○*
2011.4.1	1	1	2	17	이상무	5급 홍길○	*홍길○*	*김유○*

[별지 제6호 서식] <개정 2021.03.10.>

보조기억매체 라벨

↑
2.5cm
↓

대외비/일반/인증서			(인)
관리번호 표기			
정		부	

← 5cm →

<디스켓, 이동형 HDD 서식>

↑
1cm
↓

대외비/일반/인증서	(인)
관리번호 표기	

← 3cm →

<USB·CD 등 서식>

가. 同 서식을 만들어 보조기억매체 중앙의 적절한 위치에 부착

나. 첫 번째 줄에는 보직자의 직인을 날인

다. 두 번째 줄에는 보조기억매체 관리번호 표기

ex) 부서명 - 대외비/일반/인증서 - 000000(6자리)

라. 세 번째 줄의 '정'란에 보직자, '부'란에 사용자 표기
(USB메모리 및 CD의 경우 생략)

마. 보조기억매체의 크기를 고려하여 서식·글자 크기 조정 가능

[별지 제7호서식] <개정 2021.03.10.>

휴대용 저장매체 불용처리 확인서

아래와 같이 휴대용 저장매체(　종　점) 불용처리 및 휴대용 저장매체 (　종　점) 재사용에 대해 확인을 요청함

연번	관리번호 (S/N)	매체형태	사유	불용처리	재사용
1	00부서-일반-01 (E-D900-04-3705B)	USB	고장	물리적 파기	
2	00부서-Ⅲ급-01 (5101-53RA-12567)	CD	고장	물리적 파기	
3	00부서-Ⅱ급-01 (610-RURQ-61750)	USB	용도전환	자성소거	총무과-일반-09
4					
5					
6					
7					
8					
9					
10					

확인일자 :　　년　　월　　일

요 청 자 :　　소속・직책　　O급 성명 :　　(인)

확 인 자 :　　O급 성명 :　　(인)